

DORA Exit-Strategie fuer Microsoft 365

Praxisleitfaden fuer Kundentermine, Auditrachweise und Umsetzungsplanung

Ziel: Der Kunde soll nachweisen koennen, dass Microsoft 365-Dienste, die kritische oder wichtige Funktionen unterstuetzen, kontrolliert ersetzt, uebertragen oder intern reintegriert werden koennen.

Stand: 11.05.2026

Dokumenttyp: DORA Exit-Strategie / M365 Third-Party Risk Management

Hinweis: Dieses Dokument ist eine technische und organisatorische Arbeitshilfe. Es ersetzt keine Rechtsberatung und keine finale regulatorische Bewertung.

Management Summary

DORA verlangt fuer ICT Services, die kritische oder wichtige Funktionen unterstuetzen, dokumentierte, getestete und periodisch gepruefte Exit-Strategien. Fuer Microsoft 365 betrifft das insbesondere Identitaet, E-Mail, Kollaboration, Dokumente, Security, Compliance, Audit, Retention, eDiscovery und Datenportabilitaet.

Ein M365-Exit ist kein einzelner Schalter, sondern ein Programm aus Inventarisierung, Kritikalitaetsbewertung, Vertrags- und Datenanalyse, Zielarchitektur, Migration, Security-/Compliance-Kontinuitaet, Tests und Managementfreigaben.

Die wirtschaftlich und regulatorisch sinnvollste Strategie ist haeufig nicht der sofortige Komplettausstieg, sondern Exit Readiness: Der Kunde bleibt operativ auf M365, kann aber Daten, Workloads und Prozesse kontrolliert uebertragen, ersetzen oder mit Alternativen betreiben.

1. Zielbild

Eine DORA-konforme Exit-Strategie fuer Microsoft 365 soll nachweisen, dass ein Kunde Microsoft 365-Dienste, die kritische oder wichtige Funktionen unterstuetzen, kontrolliert beenden, ersetzen oder in einen Alternativbetrieb ueberfuehren kann, ohne die Geschaefsttaetigkeit, regulatorische Pflichten oder die Servicequalitaet gegenueber Kunden unvertretbar zu beeintraehtigen.

Bei Microsoft 365 bedeutet Exit nicht zwingend, dass alle Microsoft-Dienste sofort verlassen werden. Ein tragfaehiges Zielbild kann auch aus kontrollierter Portabilitaet, Tenant-to-Tenant-Umzug, Multi-Provider-Strategie, Workload-Splitting, Datenexportfaehigkeit, Ersatzprozessen und getesteten Notfallmassnahmen bestehen.

DORA verlangt fuer ICT Services, die kritische oder wichtige Funktionen unterstuetzen, umfassende, dokumentierte, ausreichend getestete und periodisch ueberpruefte Exit Plaene. Dazu gehoeren alternative Loesungen und Uebergangsplaene, um die bezogenen ICT Services und relevanten Daten sicher und vollstaendig zu alternativen Providern zu uebertragen oder intern zu reintegrieren. [1]

2. Scope der Exit-Strategie fuer M365

Die Exit-Strategie muss auf Ebene der Funktionen und Workloads geplant werden. Nicht jeder Microsoft 365-Dienst ist automatisch kritisch, aber jeder Dienst kann kritisch werden, wenn er eine wichtige Funktion, regulatorische Aufbewahrung, Kundenkommunikation, Identitaetssteuerung oder Sicherheitsueberwachung traegt.

Typische M365-Bereiche im Scope sind: Exchange Online, SharePoint Online, OneDrive, Teams, Microsoft Entra ID, Intune, Defender XDR, Defender for Office 365, Defender for Endpoint, Defender for Cloud Apps, Microsoft Purview, Compliance Manager, Audit, eDiscovery, DLP, Sensitivity Labels, Power Platform und Schnittstellen zu Azure, SIEM, Archiv, Backup, ITSM und IAM.

3. Grundsatzfragen im Kundentermin

Welche Geschaeftsprozesse wuerden ausfallen, wenn Exchange Online, Teams, SharePoint/OneDrive, Entra ID oder Purview nicht verfuegbar waeren?

Welche dieser Prozesse sind als kritisch oder wichtig klassifiziert?

Gibt es bereits ein Register der vertraglichen Vereinbarungen und Dienstleister mit Kritikalitaet, Datenarten, Owner, Standort, Subunternehmern, SLA, Vertragslaufzeit und Exit-Anforderungen?

Sind Daten, Berechtigungen, Aufbewahrungsregeln, Labels, Legal Holds, Audit Logs, Apps, Power Automate Flows, SharePoint Sites, Teams und Integrationen inventarisiert?

Gibt es eine dokumentierte Alternative fuer E-Mail, Kollaboration, Identitaet, Device Management, Security Monitoring, DLP, eDiscovery und Archivierung?

Wurde ein Exit oder Teil-Exit bereits technisch getestet, beispielsweise Datenexport, Mailrouting, Identitaetswechsel, Wiederherstellung, neue Kollaborationsplattform, eDiscovery-Nachweis oder Backup-Restore?

Welche Vertrags-, Lizenz-, Datenschutz-, Aufsichts- und Kundenkommunikationspflichten werden durch einen Exit ausgeloeset?

4. Exit-Ausloeser nach DORA-Logik

Ein Exit muss nicht erst bei Vertragsende relevant sein. DORA nennt insbesondere Risiken beim ICT-Drittanbieter, moegliches Versagen des Providers, Verschlechterung der Servicequalitaet, Geschaeftsunterbrechung durch unangemessene oder fehlgeschlagene Leistungserbringung, materielle Risiken fuer die kontinuierliche Bereitstellung des Dienstes und Beendigungsgruende aus Vertrags- oder Aufsichtssicht. [1]

Fuer M365 sollten diese Ausloeser in ein Entscheidungsmodell uebersetzt werden: schwerwiegende dauerhafte Service-Degradation, Verlust regulatorisch benoetigter Nachweise, unbeherrschbare Konzentrationsrisiken, nicht akzeptable Vertrags- oder Subunternehmerlage, unzureichende Audit- oder Zugriffsmoeglichkeiten, laengerfristige Nichterfuellung von Compliance-Anforderungen oder strategische Entscheidung zur Providerdiversifizierung.

5. Voraussetzungen, bevor eine Exit-Strategie ueberhaupt ausfuehrbar ist

1. Vollstaendiges Service- und Abhaengigkeitsinventar: Tenant, Domains, Benutzer, Gruppen, Rollen, Apps, Sites, Teams, Mailboxen, Defender/Purview-Konfigurationen, Datenfluesse, Schnittstellen und Workloads muessen bekannt sein.
2. Kritikalitaetsbewertung: Jeder Workload muss mit der unterstuetzten Geschaeftsfunktion, Kritikalitaet, RTO, RPO, Datenklasse und regulatorischen Pflicht verknuepft sein.
3. Datenportabilitaet: Der Kunde muss wissen, welche Daten exportiert werden koennen, in welchem Format, mit welcher Geschwindigkeit, mit welchem Tool, mit welchen Berechtigungen und mit welchem Qualitaetsnachweis.
4. Zielarchitektur: Es muss eine Alternative geben - neuer M365-Tenant, anderer SaaS-Anbieter, Hybridbetrieb, On-Premises, souveräne Cloud, Archivloesung, externer MSP oder manuelle Notfallprozesse.
5. Identitaetsstrategie: Domains, Entra ID, Identitaetsquellen, Conditional Access, MFA, PIM, Gruppen, Applikationsberechtigungen und Federation muessen in einen Zielzustand ueberfuehrt oder ersetzt werden.
6. Vertrags- und Lizenzbereitschaft: Ziellanbieter, Lizenzen, Migrationswerkzeuge, Support, Datenschutzvereinbarungen, Subunternehmerinformationen und Exit-Rechte muessen vor dem Cutover verfuegbar sein.
7. Sicherheits- und Compliance-Betrieb: Monitoring, Incident Response, eDiscovery, Aufbewahrung, DLP, Audit, Klassifizierung und Security Alerts muessen waehrend und nach dem Exit weiter funktionieren.
8. Tests und Nachweise: Es muessen Testplaene, Testergebnisse, Lessons Learned, Managementfreigaben und periodische Reviews vorhanden sein.

6. Strategische Exit-Optionen fuer Microsoft 365

Option A - Kontrollierter Verbleib mit Exit Readiness: Microsoft 365 bleibt Hauptplattform, aber Portabilitaet, Backup, Export, Vertragsnachweise, STP-Evidence, alternative Kommunikationswege und Workload-Notfallprozesse werden dokumentiert und getestet.

Option B - Tenant-to-Tenant Migration: Wechsel in einen anderen Microsoft 365-Tenant, etwa bei Konzernumbau, Carve-out, Providerwechsel oder Trennung. Microsoft beschreibt Cross-Tenant Migration als Migration von Workloads wie Exchange Online, SharePoint und OneDrive in einen anderen Tenant; bestimmte Workloads und Funktionen sind je nach Dienst nicht oder nur eingeschaenkt unterstuetzt. [5]

Option C - Multi-Provider-/Hybridstrategie: Kritische Funktionen werden auf mehrere Anbieter oder Betriebsmodelle verteilt, beispielsweise M365 fuer Produktivitaet, separates Archiv/eDiscovery, unabhaengiges SIEM, Drittanbieter-Backup und alternative Kommunikation.

Option D - Migration zu anderem SaaS-Provider: Wechsel zu einer alternativen Kollaborations- und E-Mail-Plattform. Hier sind Identitaet, Mailrouting, Datenmigration, DLP, Archivierung, eDiscovery, Teams-Ersatz und User Adoption kritische Themen.

Option E - Re-Insourcing oder Private/Sovereign Platform: Ausgewaehlte Funktionen werden intern oder bei einem spezialisierten Provider betrieben. Dies kann regulatorisch attraktiv sein, erfordert aber Betriebskompetenz, Sicherheit, Skalierung, Monitoring, Backup und Resilienz auf Kundenseite.

Option F - Workload-Splitting: Nicht alle M365-Dienste werden verlassen. Der Kunde definiert Exit-Pfade je Workload, etwa Exchange bleibt, aber Archiv/eDiscovery wird extern; oder Teams wird ersetzt, SharePoint bleibt als Dokumentenplattform.

7. Workload-spezifische Exit-Planung

Workload	Zu klaeren	Exit-Moeglichkeiten	Besondere Risiken
Exchange Online	Mailboxen, Kalender, Kontakte, Mailrouting, Shared Mailboxes, Archive, Holds, Journaling, Transport Rules.	PST/eDiscovery Export, Cross-Tenant Mailbox Migration, Drittanbieter-Migration, Ziel-Mailplattform.	Holds koennen Migrationen blockieren; Client-Regeln, Signaturen, bestimmte Berechtigungen und Teams-Chatinhalte sind gesondert zu planen. [6]
SharePoint Online	Sites, Dokumente, Metadaten, Versionen, Berechtigungen, Listen, Teams-verbundene Sites.	Tenant-to-Tenant, Drittanbieter-Migration, Graph/SharePoint APIs, Archivexport.	Workflows, Apps, Power Platform-Abhaengigkeiten, Pfadlaengen, sehr grosse Sites und Berechtigungsmodelle frueh pruefen. [5]
OneDrive	Benutzerdaten, Berechtigungen, Freigabelinks, Versionen, persoenliche Datenablaegen.	Tenant-to-Tenant, Migrationstools, Benutzerkommunikation, Delta-Sync.	Legal Holds, grosse Datenmengen, inaktive Benutzer und lokale Sync-Konflikte vorbereiten. [5]
Teams	Chats, Kanalbeitraege, Teams-Struktur, Meetings, Telefonie, Apps, Tabs, Dateien.	Teilweise Migration ueber Drittanbieter, Export/eDiscovery fuer Nachweis, neue Plattform oder neuer Tenant.	Teams ist einer der schwierigsten Exit-Bereiche; Chat-/App-/Meeting- und Telefonie-Szenarien gesondert planen.
Entra ID	Identitaeten, Gruppen, Rollen, App Registrations, Enterprise Apps, Conditional Access, PIM.	Ziel-IAM, Federation, Domain-Cutover, App-Neuregistrierung, Gruppenmapping.	Ohne Identitaets- und Domainstrategie ist kein kontrollierter M365-Exit moeglich.
Intune	Geraeteverwaltung, Compliance Policies, Configuration Profiles, Autopilot, Apps.	Neues MDM, Re-Enrolment, Co-Management, staged device migration.	Endgeraete koennen nicht nur per Datenmigration ueberfuehrt werden; Re-Enrollment und Benutzerfuehrung sind kritisch.
Defender XDR	Incidents, Alerts, Advanced Hunting, Endpoint-, Office-, Identity-, Cloud-App-Signale.	Export relevanter Incidents/Reports, Ziel-SOC/SIEM, paralleler Betrieb.	Detektionsfaehigkeit darf waehrend der Exit-Phase nicht abbrechen.
Purview	Audit, eDiscovery, DLP, Labels, Retention, Records Management, Compliance Manager.	Export von Audit-/eDiscovery-Ergebnissen, neue GRC-/DLP-/Archiv-Plattform, Mapping der Regeln.	Retention, Legal Hold und Records duerfen nicht unbeabsichtigt verloren gehen.
Power Platform	Power Apps, Power Automate, Connectors, Dataverse, Abhaengigkeiten.	App-Inventar, Connector-Analyse, Rebuild oder Migration.	Automationen sind oft unsichtbare Prozessabhaengigkeiten; frueh inventarisieren.

8. Minimaler Exit-Plan: Dokumentenstruktur

Ein belastbarer Exit-Plan fuer Microsoft 365 sollte mindestens folgende Kapitel enthalten:

1. Scope und kritische Funktionen
2. Ausloeser und Entscheidungsmodell

3. Service- und Dateninventar
4. Vertrags-, Lizenz- und Datenschutzgrundlagen
5. Zielarchitektur und alternative Loesungen
6. Migrations- und Uebergangsplan je Workload
7. Sicherheits-, Compliance- und Audit-Kontinuitaet
8. Datenexport, Datenloeschung, Datenrueckgabe und Beweissicherung
9. Rollen, RACI, Kommunikationsplan und Kunden-/Aufsichtsinteraktion
10. Testplan, Testnachweise, Review-Zyklus und Verbesserungsmassnahmen

9. Datenexport und Beweissicherung

Der Kunde muss vor einem Exit wissen, welche Daten exportiert werden muessen, welche Daten nur aus Compliance-/Archivgruenden aufzubewahren sind und welche Daten tatsaechlich in eine neue Produktivplattform uebergehen.

Fuer Audit- und Aufsichtsfaehigkeit sollten Exportprotokolle, Hashwerte oder Stichproben, Anzahl Objekte, Fehlerraten, Berechtigungsuebernahme, Delta-Migrationen und Freigaben dokumentiert werden.

Microsoft 365 Backup kann fuer Backup- und Restore-Szenarien eingesetzt werden und ist auf schnelle Wiederherstellung fuer Exchange Online, SharePoint und OneDrive ausgelegt. Microsoft beschreibt dabei Append-Only Backup Storage und Schutz gegen boeswillige Ueberschreibungen fuer geschuetzte Daten. [7] Ein Backup ist aber nicht automatisch ein vollstaendiger Exit-Ersatz, weil Zielplattform, Datenformat, Metadaten, Berechtigungen und Compliance-Kontext gesondert geklaert werden muessen.

10. Microsoft-Nachweise fuer die Exit-Strategie

Microsoft stellt im DORA Compliance Hub Ressourcen bereit, die Finanzunternehmen bei Governance, operativer Resilienz, Incident Reporting, Business Continuity und Drittparteirisiken unterstuetzen koennen. [2]

Das Service Trust Portal liefert Auditberichte, Compliance-Unterlagen, Whitepaper, BCP/DR-Dokumente, Penetration-Test- und Security-Assessment-Informationen sowie branchenspezifische Ressourcen. Fuer viele Dokumente sind Anmeldung, geeignete Rollen und Akzeptanz der Microsoft-Vertraulichkeitsbedingungen erforderlich. [4]

Microsoft Purview Compliance Manager kann Bewertungen, Controls, Improvement Actions und Exportberichte fuer interne Stakeholder, Pruefer und Regulatoren bereitstellen; technische und nichttechnische Verbesserungsmassnahmen werden dabei getrennt verwaltet. [3]

Diese Microsoft-Nachweise ersetzen nicht den kundeneigenen Exit-Plan. Sie sind Lieferanten- und Kontrollnachweise, die in die eigene DORA-Dokumentation eingebunden werden sollten.

11. Test- und Review-Konzept

Eine DORA-taugliche Exit-Strategie ist nur belastbar, wenn sie getestet und periodisch ueberprueft wird. Ein reiner Papierplan reicht nicht.

Empfohlene Tests:

1. Tabletop Exercise: Management, IT, Legal, Compliance, Datenschutz, Einkauf und Fachbereich simulieren einen M365-Exit-Ausloeser.

2. Datenexport-Test: Stichproben aus Exchange, SharePoint, OneDrive und Purview werden exportiert und auf Lesbarkeit, Vollstaendigkeit und Berechtigungsinformationen geprueft.
3. Identitaets- und Domain-Cutover-Test: Ziel-IAM, DNS, Mailrouting und Authentifizierung werden in einer isolierten oder Pilotumgebung getestet.
4. Restore-Test: Wiederherstellung kritischer Daten aus Backup oder Archiv wird nachgewiesen.
5. eDiscovery-/Audit-Test: Nach dem Export oder in der Zielumgebung wird geprueft, ob regulatorische Such- und Nachweispflichten weiterhin erfuehrt werden.
6. Betriebsuebergabe-Test: SOC, Helpdesk, Monitoring, Incident Response und Change Management arbeiten im Zielmodell.

12. RACI fuer den Kunden

Rolle	Verantwortung
Management Body	Genehmigt Strategie, Risikoakzeptanz, Budget und Testintervall.
CIO/IT-Leitung	Verantwortet Zielarchitektur, Migration, Betriebskontinuitaet und technische Umsetzbarkeit.
CISO/Security	Bewertet Security-Risiken, Monitoring, Incident Response, Zero Trust und Schutzmassnahmen.
Compliance/DORA Owner	Fuehrt regulatorische Anforderungen, Nachweise, Review und Auditkoordination.
Legal/Einkauf	Prueft Verträge, Kuendigung, Datenrueckgabe, Subunternehmer, SLA und Exit-Rechte.
Datenschutz	Bewertet personenbezogene Daten, AVV/DPA, Loeschung, Datenuebertragung und Betroffenenrechte.
Fachbereich	Bestaetigt Kritikalitaet, RTO/RPO, Workarounds und Akzeptanztests.
MSP/Partner	Unterstuetzt Inventar, Export, Migration, Tests, Evidence Packs und Betrieb.

13. Entscheidungs- und Reifegradmodell

Reifegrad	Beschreibung
0 - Nicht vorhanden	Kein dokumentierter Exit-Plan, kein Inventar, keine klare Alternative.
1 - Papierplan	Exit-Plan existiert, aber Workloads, Daten, Kosten und Tests sind unvollstaendig.
2 - Nachweisbar geplant	Inventar, Zieloptionen, Rollen, Vertragslage und Nachweise sind dokumentiert.
3 - Teilweise getestet	Kritische Workloads wurden in Stichproben exportiert, wiederhergestellt oder migriert.
4 - Regelmässig getestet	Exit-Tests, Tabletop Exercises, Evidence Packs und Management-Reviews laufen periodisch.
5 - Operativ umsetzbar	Der Kunde kann definierte Workloads kontrolliert ueberfuehren oder ersetzen, inklusive Security, Compliance, Daten und Betrieb.

14. Managed-Service-Angebote rund um M365 Exit Readiness

Managed Service	Inhalt
M365 Exit Readiness Assessment	Inventar, Kritikalitaet, Gap-Analyse, Exit-Szenarien, Massnahmenplan.
DORA Provider Evidence Pack	STP-Downloads, SOC/BCP/DR-Nachweise, Compliance Manager Exporte, Service Health Reviews.
M365 Portability & Data Export Test	Geplanter Export von Mailboxen, Sites, OneDrive, Audit/eDiscovery-Stichproben.
Tenant-to-Tenant Migration Planning	Ziel-Tenant, Identitaet, Domains, Mailrouting, Daten, Berechtigungen, Cutover-Plan.
M365 Backup & Restore Test Service	Backup-Konzept, Restore-Test, Nachweisbericht, Lessons Learned.
Third-Party Register Managed Service	Providerregister, Kritikalitaet, Verträge, Review-Datum, Risiken und Exit-Status.
Compliance Manager Managed Service	Assessment, Improvement Actions, Evidence Links, Rollen und Exportberichte.
SOC/SIEM Continuity Service	Defender/Sentinel-Daten, Log-Retention, Use Cases, Incident Runbooks im Exit-Szenario.

BCP/Exit Tabletop Exercise	Moderierte Uebung mit Management, IT, Legal, Compliance und Fachbereichen.
Quarterly Exit Plan Review	Periodische Aktualisierung, Teststatus, neue Abhaengigkeiten, Managementreport.

15. Checkliste: Ist der Kunde exit-faehig?

Der Kunde sollte mindestens folgende Fragen mit Ja beantworten koennen:

Sind alle M365-Dienste mit kritischen oder wichtigen Funktionen verknuepft?

Gibt es fuer jeden kritischen Workload ein Zielmodell oder eine Ersatzloesung?

Sind Daten, Berechtigungen, Retention, Legal Holds, Labels, Audit Logs und Apps inventarisiert?

Gibt es eine getestete Methode fuer Datenexport, Wiederherstellung oder Migration?

Gibt es Vertragsrechte fuer Kuendigung, Datenrueckgabe, Unterstuetzung und Nachweise?

Gibt es eine Entscheidungsvorlage fuer Management und Regulatorik?

Ist bekannt, welche Microsoft-Funktionen nicht 1:1 migrieren oder exportieren?

Wurde mindestens ein Teil-Exit oder Tabletop-Test durchgefuehrt?

Gibt es ein aktuelles Evidence Pack mit STP-, Compliance Manager- und technischen Nachweisen?

Wird die Strategie regelmaessig reviewed und bei Aenderungen im Tenant aktualisiert?

16. Quellen

[1] **DORA Regulation (EU) 2022/2554, Article 28(8), EUR-Lex:** <https://eur-lex.europa.eu/legal-content/ENG/TXT/?uri=CELEX%3A32022R2554>

[2] **Microsoft Trust Center - DORA Compliance Hub:** <https://www.microsoft.com/de-de/trust-center/compliance/dora-compliance>

[3] **Microsoft Learn - Microsoft Purview Compliance Manager assessments:**
<https://learn.microsoft.com/de-de/purview/compliance-manager-assessments>

[4] **Microsoft Learn - Service Trust Portal:** <https://learn.microsoft.com/en-us/purview/get-started-with-service-trust-portal>

[5] **Microsoft Learn - Microsoft 365 cross-tenant migration / FastTrack:**
<https://learn.microsoft.com/en-us/microsoft-365/fasttrack/cross-tenant-migration>

[6] **Microsoft Learn - Cross-tenant mailbox migration:** <https://learn.microsoft.com/en-us/microsoft-365/enterprise/cross-tenant-mailbox-migration?view=o365-worldwide>

[7] **Microsoft Learn - Microsoft 365 Backup overview:** <https://learn.microsoft.com/en-us/microsoft-365/backup/backup-overview?view=o365-worldwide>